Sesión 1. Fundamentos y redes – el alcance del laboratorio

Al salir: formaliza y firma el alcance de Metasploitable 2, delimita la red autorizada y explica la tríada, los tipos de auditoría y la metodología en cuatro eslabones.

Para qué es esta guía

Al terminar, usted produce el alcance firmado de Metasploitable 2 y puede explicar la tríada de seguridad (confidencialidad, integridad y disponibilidad), los cuatro tipos de auditoría y la metodología de cuatro fases (planificar, recopilar, analizar e informar).

Usted recibe la máquina virtual Metasploitable 2 ya encendida en la LAN de laboratorio y un archivo en blanco en su cuaderno de trabajo. Si no cuenta con el laboratorio activo, toma como referencia inicial la configuración estándar informada en la clase de inducción.

La guía S02 usará este alcance firmado como su documento de entrada obligatorio para realizar el reconocimiento de servicios sin declarar hallazgos.

El auditor es usted: decide el alcance técnico, delimita la frontera de la prueba, deja como «pendiente de confirmar» lo que no le consta y estampa su firma de responsabilidad profesional. La herramienta de asistencia propone un borrador preliminar y no firma.

La gerencia y el cliente leen el alcance para autorizar formalmente la frontera de la evaluación; no deciden los procedimientos técnicos de auditoría ni juzgan la validez de la evidencia. Quien corrige revisa que su alcance proteja el resto de la red y que ningún dato no verificado haya sido firmado como hecho constatado.

El caso

El laboratorio del curso monta una auditoría técnica sobre la máquina virtual Metasploitable 2, ejecutada en VirtualBox con adaptador puente sobre la LAN de laboratorio ya aislada. Usted recibe la máquina encendida con su pantalla de inicio en consola y el encargo de formalizar el alcance antes de iniciar cualquier prueba. Queda fuera de la evaluación la máquina física anfitriona, la puerta de enlace, la red del aula e Internet. Si un dato no consta fehacientemente en la entrega, queda como pendiente de confirmar: no se inventan versiones ni parámetros para forzar el cierre.

Una auditoría técnica verifica el estado de la seguridad evaluando la tríada CIA: confidencialidad (que los datos no sean accesibles a personas no autorizadas), integridad (que la información y las configuraciones no sean alteradas indebidamente) y disponibilidad (que los servicios legítimos respondan oportunamente). Existen cuatro tipos de auditoría: técnica (revisión directa de configuraciones y sistemas), de cumplimiento (cotejo contra normas o regulaciones), interna (conducida por el propio equipo de la entidad) y externa (ejecutada por un auditor independiente). El trabajo se conduce mediante una metodología de cuatro fases: planificar (fijar el alcance y objetivos), recopilar (reunir evidencia fehaciente sin alterar el entorno), analizar (contrastar la evidencia contra el criterio de auditoría) e informar (redactar el dictamen con sus recomendaciones).

Cada término técnico que el ejercicio utiliza se define con su significado exacto, un ejemplo redactado para esta sesión y su distinción frente a conceptos afines:

- **Alcance:** Es el límite formal y consensuado que establece con exactitud qué sistemas, redes y operaciones están autorizados para la evaluación. Fija la frontera de protección jurídica y operativa del auditor y del cliente. **Ejemplo escrito:** «Entra exclusivamente la máquina virtual Metasploitable 2 en la LAN de laboratorio aislada; quedan fuera la máquina anfitriona, la puerta de enlace e Internet.» **Qué no es:** No es una lista libre de deseos del cliente ni una descripción de procedimientos de ataque.
- **Historia de usuario:** Es una declaración concisa que expresa la necesidad del auditor, la acción concreta y el propósito que persigue. Comunica en una sola oración el sentido del trabajo para que cualquier integrante del equipo entienda la frontera fijada. **Ejemplo escrito:** «Como auditor del laboratorio, quiero dejar por escrito que entra solo Metasploitable 2, para que otra persona repita el trabajo sin tocar el resto de la LAN.» **Qué no es:** No es una fórmula genérica descrita como quién, qué y para qué, sino una oración redactada con los datos reales del caso.
- **Prompt:** Es la instrucción estructurada que el auditor entrega a la herramienta para orientar la redacción de un borrador preliminar. Establece de antemano el rol, el contexto, la tarea, las restricciones y las condiciones de término. **Ejemplo escrito:** «Rol: Auxiliar de auditoría. Contexto: Laboratorio con Metasploitable 2 en adaptador puente sobre LAN aislada. Tarea: Redacte la historia de usuario y la ficha de cuatro eslabones. Listo: Hay una frase con quién, qué y para qué, la ficha tiene cuatro líneas y lo no constatado queda como pendiente de confirmar. No puede: No declare hallazgos, no nombre otra máquina y no invente normas.» **Qué no es:** No es una conversación informal ni una orden suelta de tres palabras («escribe el alcance»).
- **Spec-driven:** Es el método de trabajo donde primero se escriben y fijan las condiciones exactas de término antes de redactar el contenido o solicitarlo a la herramienta. Garantiza que el producto cumpla los requisitos de auditoría sin desvíos ni omisiones. **Ejemplo escrito:** «Definir previamente que el alcance queda listo solo si incluye historia de usuario, límites explícitos, ficha de cuatro eslabones sin hallazgos y los metadatos no confirmados escritos como «pendiente de confirmar».» **Qué no es:** No es programar código informático ni iterar a ciegas esperando que la herramienta acierte.
- **Pendiente de confirmar:** Es la anotación que el auditor escribe junto a cualquier parámetro, versión o requisito que no consta fehacientemente en la consigna o en la evidencia. Impide que se den por ciertas suposiciones o se fabriquen datos no verificados en el expediente de auditoría. **Ejemplo escrito:** «Período de evaluación: [pendiente de confirmar]; Versión del sistema operativo: [pendiente de confirmar]; Criterio normativo: [pendiente de confirmar].» **Qué no es:** No es un error ni un espacio en blanco olvidado, sino la constancia profesional de que el dato está pendiente de verificación fehaciente.
- **Ficha de cuatro eslabones (observación, evidencia, hallazgo, recomendación):** Es la estructura metodológica estándar que encadena de forma lógica y trazable el proceso de auditoría. Vincula el hecho observado con su respaldo demostrable, la discrepancia frente al criterio y la acción de mejora necesaria. **Ejemplo escrito:** «Observación: La máquina virtual Metasploitable 2 se encuentra encendida en la LAN de laboratorio. Evidencia: Pantalla de inicio de la consola visible en la ventana del hipervisor. Hallazgo: Ninguno / No aplica (en la fase de alcance no existen vulnerabilidades evaluadas ni brechas constatadas). Recomendación: Formalizar y firmar el alcance antes de iniciar cualquier prueba técnica.» **Qué no es:** No es un informe libre ni una lista de quejas, sino una cadena causal estricta donde ningún eslabón existe sin el anterior.

- **GitHub:** Es la plataforma de control de versiones utilizada para versionar, custodiar y auditar el historial de entregables del curso. Proporciona trazabilidad completa sobre los cambios documentales y el momento exacto de su publicación. **Ejemplo escrito:** «Registrar en su repositorio el borrador del alcance firmado y la ficha metodológica en la entrega de la sesión 1.» **Qué no es:** No es un repositorio de almacenamiento desordenado ni un lugar para subir credenciales, contraseñas o el archivo .env.

Desafíos

1. Deje por escrito el alcance de Metasploitable 2

Objetivo del desafío. Usted aplica las reglas de formalización de alcance de auditoría redactando el documento formal de Metasploitable 2.

Entrada. Abre la máquina virtual Metasploitable 2 encendida en VirtualBox (con adaptador puente en la LAN de laboratorio aislada), la consola del sistema y un archivo en blanco en su cuaderno de trabajo.

Qué hace, en orden:

- **Paso 1.** Escriba la historia de usuario del alcance en una sola oración formal: «Como auditor del laboratorio, quiero dejar por escrito que entra solo Metasploitable 2, para que otra persona repita el trabajo sin tocar el resto de la LAN».
- **Paso 2.** Escriba la sección de límites en dos oraciones exactas: la primera establece que el único activo autorizado es Metasploitable 2 en la LAN de laboratorio aislada; la segunda declara explícitamente que la máquina física anfitriona, la puerta de enlace y cualquier otro equipo de la red quedan fuera de alcance.
- **Paso 3.** Registre los metadatos de auditoría y deje como pendiente de confirmar todo parámetro que no conste en la entrega: período de evaluación [pendiente de confirmar], versión del sistema operativo [pendiente de confirmar], marco normativo aplicable [pendiente de confirmar].
- **Paso 4.** Redacte la ficha metodológica de cuatro eslabones: Observación (máquina Metasploitable 2 encendida en LAN de laboratorio aislada), Evidencia (pantalla de inicio de la consola visible en la ventana del hipervisor), Hallazgo (Ninguno / No aplica: declare expresamente que en esta etapa no hay hallazgos de vulnerabilidad) y Recomendación (formalizar la aprobación de este alcance antes de iniciar pruebas técnicas).
- **Paso 5.** Estampe su firma de responsabilidad profesional al pie del documento con su nombre completo, rol de auditor técnico y fecha actual.

Qué anota. El texto visible en su cuaderno de trabajo debe estructurarse con estos apartados: historia de usuario redactada; límites de activos autorizados y excluidos; metadatos, con lo pendiente de confirmar a la vista; ficha de cuatro eslabones completa; y bloque de firma del auditor.

Cuándo queda listo. La tarea se considera terminada cuando cumple todas estas condiciones observables:

- La historia de usuario está escrita completa con rol, acción y propósito.
- Metasploitable 2 es el único activo incluido en el alcance y el resto de la red figura expresamente excluido.
- Los datos no constatados dicen expresamente «pendiente de confirmar».
- La ficha de cuatro eslabones está completa y declara «Ninguno / No aplica» en la línea de hallazgo.
- No existe ningún comando de escaneo, exploit, puerto atacado ni credencial en el texto.

- El documento está firmado por usted con su nombre y rol.

Prompt de ejemplo. Un bloque estructurado con sus cinco partes:

> **Rol.** Usted es un auxiliar de auditoría técnica. No firma el documento.
>
> **Contexto.** El laboratorio es Metasploitable 2, en VirtualBox con adaptador puente sobre la LAN de laboratorio aislada. Entra solo esa máquina virtual.
>
> **Tarea.** Redacte la historia de usuario y la ficha de cuatro eslabones para formalizar el alcance de la auditoría.
>
> **Listo.** Hay una frase con quién, qué y para qué. La ficha tiene las cuatro líneas (observación, evidencia, hallazgo y recomendación). Lo que no está en la consola queda como pendiente de confirmar. En hallazgo se declara «Ninguno / No aplica».
>
> **No puede.** No declare hallazgos de vulnerabilidad. No nombre otra máquina ni la red anfitriona. No invente una norma ni proponga credenciales o comandos.

Cómo se armó este prompt: El apartado «Listo» del prompt es exactamente el mismo criterio de «Cuándo queda listo» de este desafío. Esto es construir de forma spec-driven: la especificación de término gobierna la instrucción antes de solicitar la generación. Copie este bloque de prompt, pida el borrador a la herramienta, tache y corrija minuciosamente lo que no le conste y estampe su firma como auditor responsable.

Qué se firma y qué no

- **Puede dar por bueno:** El alcance delimitado que autoriza exclusivamente a la máquina virtual Metasploitable 2; la historia de usuario formulada con su rol de auditor; la ficha de cuatro eslabones que constata la máquina encendida sin atribuir vulnerabilidades; y la configuración de red en adaptador puente sobre la LAN de laboratorio aislada.
- **Debe dejar como pendiente de confirmar:** La versión exacta del sistema operativo que no figure en la pantalla inicial; el marco normativo o estándar del informe final; y las fechas y horas exactas no especificadas en la consigna.
- **No se firma:** Una credencial o contraseña (por ejemplo de la consola o de servicios del sistema); el archivo .env o claves de configuración; un hallazgo de vulnerabilidad sin evidencia técnica verificada; ni un borrador propuesto por una herramienta de inteligencia artificial que usted no haya comprobado y validado personalmente.

Trabajo asíncrono

Entregue el documento de alcance firmado en su repositorio de GitHub. Verifique rigurosamente antes de publicar que el documento no contenga contraseñas, credenciales de acceso ni archivos de entorno .env. Esta guía no trae cuestionario propio: el Cuestionario Unidad 1 está en la sección de la unidad.

Herramienta que se lleva

Usted se lleva una estructura reutilizable de alcance y ficha de cuatro eslabones construida bajo enfoque spec-driven. En la siguiente sesión y en futuras auditorías reales, reutilizará este mismo esquema

metodológico manteniendo intactos los apartados de historia, límites y verificación, y modificando únicamente el activo autorizado que el caso defina como variable. La herramienta de asistencia podrá proponer las redacciones preliminares, pero el control del alcance, la verificación contra evidencia fehaciente y la firma seguirán siendo siempre su responsabilidad profesional indelegable.